

Threat Analysis Report

รายงานวิเคราะห์การจารกรรมไซเบอร์เป้าหมายหน่วยงาน
ในประเทศไทย โดยใช้ AI Agent “Hermes”
แบบไร้การควบคุม และ Implant “Hades”

CVE-2026-43503 (CVSS 7.8)

CVE-2026-31431 (CVSS 7.8)

CVE-2026-43284 (CVSS 7.8)

CVE-2026-43500 (CVSS 7.8)

CVE-2021-3156 (CVSS 7.8)

CVE-2021-4034 (CVSS 7.8)

CVE-2017-7269 (CVSS 9.8)

24/07/2026

TLP:CLEAR



สารบัญ

บทสรุปสำหรับผู้บริหาร.....	3
Threat Actor Profiles	4
การวิเคราะห์เชิงเทคนิค.....	5
Tactics, Techniques, and Procedures (MITRE ATT&CK)	8
Indicators of Compromise (IoCs)	10
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ	14
อ้างอิง (References).....	16

บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้เป็นการวิเคราะห์เชิงลึกเกี่ยวกับการโจมตีทางไซเบอร์เพื่อการจารกรรมข้อมูล (Cyber Espionage) มุ่งเป้าหน่วยงานในประเทศ โดยถูกบุกรุกจากกลุ่มผู้ก่อเหตุไม่หวังดีที่มีความเชื่อมโยงกับกลุ่มภัยคุกคามที่ใช้ภาษาจีน (Sinophone Threat Actor) จุดเปลี่ยนสำคัญของการโจมตีในครั้งนี้คือ การใช้นวัตกรรมปัญญาประดิษฐ์เอเจนต์อิสระ (Autonomous AI Agent) ชื่อ “Hermes” ซึ่งเป็นโมเดล AI โอเพนซอร์สที่ถูกนำมารันในโหมด “YOLO” (Unattended Mode) ข้ามกระบวนการขออนุมัติจากมนุษย์ เอเจนต์นี้ทำหน้าที่สแกนค้นหาช่องโหว่ สแกนหาการยกระดับสิทธิ์ (LinPEAS) และสำรวจดึงดัชนีไฟล์เอกสารชั้นลับในระบบเว็บของหน่วยงาน เป้าหมายโดยอัตโนมัติ จากการวิเคราะห์สารบบเปิด (Open Directories) บนเครื่องเซิร์ฟเวอร์แสดงจิ้งของผูโจมตี หมายเลข IP 43.246.208[.]207 (โฮสต์ฮ่องกง) พบไฟล์มั่วร้ายและข้อมูลที่เกี่ยวข้อง 585 ไฟล์ รวม 470 MB ประกอบด้วย:

1. โครงสร้างเป้าหมายเฉพาะทาง: ไฟล์คอนฟิกที่ระบุการเข้าถึงระบบภายในของหน่วยงาน เป้าหมาย เช่น ระบบ Admin Dashboard, ระบบบิกิตต้า HiveServer2, WebHDFS, HDFS DataNode, GlassFish Admin Console, ระบบจัดการเอกสาร Alfresco และระบบจัดการการเงิน
2. มัลแวร์ Hades: แอปคอร์ดฝังตัวเขียนด้วยภาษา Go จำนวน 62 รูปแบบ (Windows PE และ Linux ELF) รองรับการจับภาพหน้าจอ, Process Hollowing, สื่อสารผ่าน HTTPS ใช้รหัส AES-256-GCM ตบตาดด้วย URI ปลอม และกลไกทำลายตัวเอง (Killdate)
3. HiveServer2 / Hadoop Exploitation Toolkit: สคริปต์เจาะระบบบิกิตต้าผ่านช่องโหว่ SASL PLAIN (โหมด NONE) และรับผลลัพธ์ผ่าน WebHDFS
4. GlassFish Console Automator: สคริปต์ Node.js + Puppeteer นำทางผ่าน SOCKS5 พร็อกซี เข้าล็อกอินหน้าคอนโซล GlassFish ด้วยรหัสผ่านเริ่มต้น เพื่อฝัง JSP Web Shell
5. Password Spraying Framework: สคริปต์สเปรย์รหัสผ่านอีเมลเจ้าหน้าที่โดยใช้ Wordlist ตัวอย่างของหน่วยงานภายในเป้าหมาย

ปัจจุบันยังไม่พบหลักฐานเชิงประจักษ์ของการนำข้อมูลออกนอกเครือข่าย (No Evidence of Data Exfiltration) แต่พบการเข้าถึงและจัดทำสารบัญเอกสารยุทธศาสตร์และบุคลากร

Threat Actor Profiles

TA Name: Unidentified Sinophone Cyber Espionage Group (กลุ่มจารกรรมไซเบอร์ที่ใช้ภาษาจีนซึ่งยังไม่ระบุชื่อ)

- ประวัติและภูมิหลัง: เซิร์ฟเวอร์หลัก 43.246.208[.]207 มีประวัติเคยเป็นเครื่องควบคุมมัลแวร์ ShadowPad และปัจจุบันเปิดบริการ C2 ของมัลแวร์ VShell บนพอร์ต 21083 ไฟล์ระบบพบ IP ขาเข้าผ่าน SSH จากฮ่องกง (103.97.0[.]57) นอกจากนี้ มีการตั้งค่ารหัสผ่านเข้าถึง Web UI ของ Hermes ซึ่งมีคำว่า “Leishen” (雷神 - เทพเจ้าแห่งสายฟ้า) รวมถึงมีการใช้ FOFA API Key (แพลตฟอร์มค้นหาของจีน)
- ระดับทักษะและพฤติกรรม: มีความเชี่ยวชาญสูงในการพัฒนาเครื่องมือเฉพาะทาง (Custom Go-Implant) และผสมผสาน AI อัตโนมัติ แต่ยังมีข้อผิดพลาดด้าน OPSEC (ปล่อยเซิร์ฟเวอร์เปิดโล่งให้เข้าถึงสารระบบได้)
- แรงจูงใจ: การจารกรรมข้อมูลเชิงนโยบายและบุคลากร (Cyber Espionage) ไม่พบพฤติกรรมเรียกค่าไถ่

การวิเคราะห์เชิงเทคนิค

Attack Flow

1. Initial Access & Pivoting (การเข้าถึงเริ่มต้นและการเชื่อมต่อผ่านตัวกลาง)

- การเชื่อมต่อจากภายนอก: ผู้โจมตี (Attacker / Operator) เริ่มต้นด้วยการสร้างการเชื่อมต่อเข้ารหัสแบบ **SSH Tunnel** จากเครือข่ายภายนอกเข้ามายัง **Staging Server** (หมายเลข IP: 43.246.208.207)
- การเจาะเข้าเครือข่ายภายใน: จาก Staging Server ผู้โจมตีใช้ **SOCKS5 Proxy** (ผ่านพอร์ต 127.0.0.1:1111) เป็นตัวกลาง (Pivot) เพื่อเจาะทะลุผ่านเข้าไปยังเครือข่ายภายในของเป้าหมาย (Target Internal Network)

2. Exploitation & Discovery (การโจมตีและการสำรวจเครือข่ายภายใน)

เมื่อเข้ามาในเครือข่ายภายในได้แล้ว ผู้โจมตีได้แยกเส้นทางการทำงานออกเป็น 3 ส่วนหลัก ได้แก่:

- **Exploitation Path 1 (การโจมตี GlassFish):**
 - ผู้โจมตีเข้าถึง **Internal GlassFish Console** โดยใช้รหัสผ่านพื้นฐานที่ไม่ได้ถูกเปลี่ยน (Default Creds)
 - จากนั้นทำการอัปโหลดไฟล์ (Deploy WAR) เพื่อฝัง **JSP Web Shell** สำหรับใช้ควบคุมระบบในระดับแอปพลิเคชัน
- **Exploitation Path 2 (การโจมตี HiveServer2):**
 - ผู้โจมตีเข้าถึง **Internal HiveServer2** โดยอาศัยการตั้งค่าการยืนยันตัวตนที่หละหลวม (SASL PLAIN Mode NONE)
 - ทำการลงทะเบียนฟังก์ชันพิเศษ (Register UDF) เพื่อรันไฟล์ HiveCmd.jar
 - นำไปสู่การรันคำสั่งในระดับระบบปฏิบัติการ (OS Execution) และส่งผลลัพธ์ที่ได้ออกไปยัง **WebHDFS Node**
- **Discovery / AI Autonomous Scan (การสำรวจอัตโนมัติด้วย AI):**
 - ระบบใช้ **Hermes AI Agent** ที่ทำงานในโหมด "YOLO" เพื่อสแกนหาเป้าหมายและข้อมูลโดยอัตโนมัติ

- ระบบเซิร์ฟเวอร์ภายใน (Internal Servers): รันสคริปต์ LinPEAS และทำการสแกน SUID เพื่อหาช่องทางยกระดับสิทธิ์ (Privilege Escalation)
- ระบบจัดการเอกสาร (Document Management System): ทำการค้นหาและทำดัชนีข้อมูล (Index Search) เพื่อหาข้อมูลสำคัญ

3. Payload Delivery & Execution (การส่งมอบและการรันมัลแวร์)

ในขณะเดียวกัน มีการส่งมอบมัลแวร์หลักเพื่อฝังตัวในเครื่องของเหยื่อ:

- **Payload Delivery:** Staging Server ทำการส่งมัลแวร์ที่พัฒนาด้วยภาษา Go ชื่อ Hades Implant ลงมายังระบบเป้าหมาย
- **การทำงานบน Windows Endpoint:** มัลแวร์ใช้เทคนิค Process Hollowing โดยนำโค้ดอันตรายไปแฝงตัวทำงานอยู่ภายใต้โปรเซสที่ดูปกติของระบบอย่าง svchost.exe เพื่อหลบเลี่ยงการตรวจจับ
- **การทำงานบน Linux Endpoint:** มัลแวร์ถูกส่งรันขึ้นมาทำงานโดยตรง (Direct Execution)

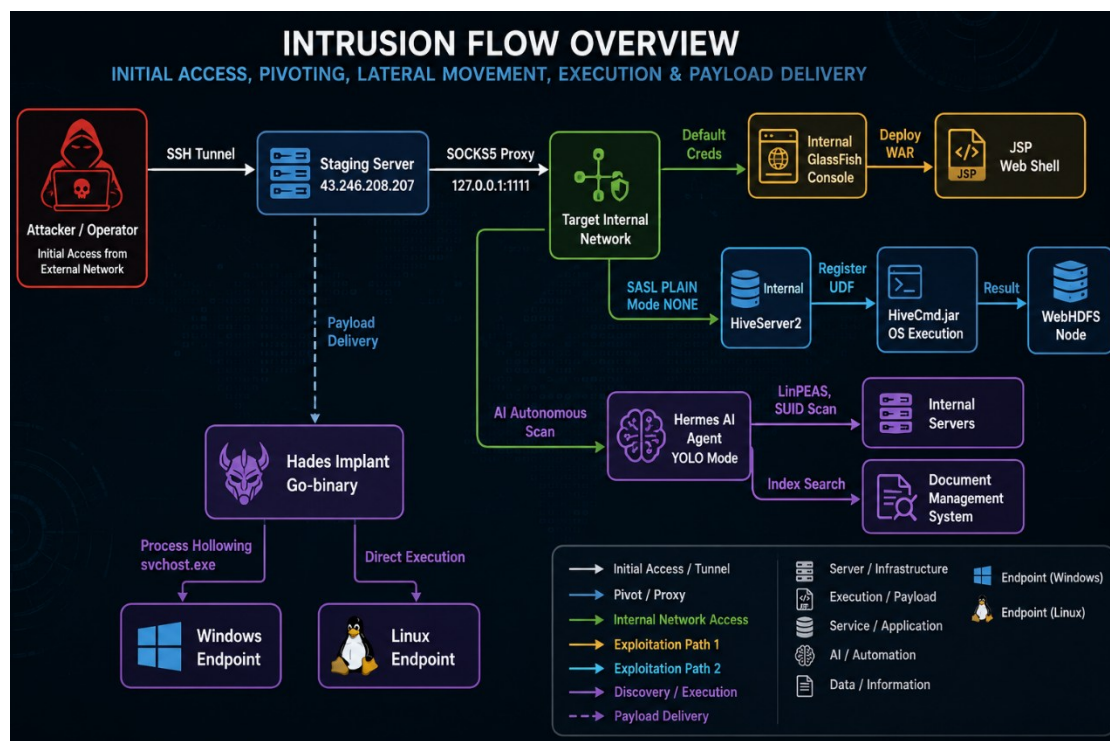


Figure 1 Attack Flow

การปฏิบัติการด้วย AI Agent แบบอิสระ (Hermes)

- Hermes ถูกนำมารันใน YOLO Mode ซึ่งห้ามการขออนุมัติจากมนุษย์เมื่อรันคำสั่งความเสี่ยงสูง AI Agent ทำการสำรวจระบบด้วยตนเอง ดังนี้:
 - การประเมินการยกระดับสิทธิ์ สแกนหาช่องโหว่ Linux Kernel
 - การรันสคริปต์ LinPEAS และค้นหาไบนารีที่มีสิทธิ์ SUID/SGID ผิดปกติ
 - ค้นหาไฟล์เอกสารสำคัญแบบย้อนกลับ ทำให้เกิด “Command Cadence” ที่เร็วกว่ามนุษย์จนเกิด Broken-pipe Error

โครงสร้างและเทคนิคของมัลแวร์ Hades

- Platform: รองรับทั้ง Windows (PE) และ Linux (ELF)
- Masquerading: พรางชื่อเป็น ctfdmon.exe, csrss.exe, kworker, multipathd
- In-Memory Execution: ฝั่ง Windows ใช้ Process Hollowing เข้าไปใน svchost.exe ส่วน Linux รัน Shellcode โดยตรง
- Stealth: ใช้ URI ปลอม (/assets/app.min.js, /assets/vendor.js) ในการติดต่อ C2 และเข้ารหัส Payload ด้วย AES-256-GCM
- Guardrails: มีตัวแปร HADES_KILLDATE กำหนดวันทำลายตัวเอง และกำหนดเวลาทำงาน (Working-hours Window)

เทคนิคเจาะช่องโหว่ยกระดับสิทธิ์ (Privilege Escalation)

ผู้โจมตีจัดเตรียมคลัง Exploit ระดับ Kernel รวมถึงช่องโหว่ใหม่:

- CVE-2021-3156 (Sudoedit)
- CVE-2021-4034 (PwnKit)
- CVE-2017-7269 (IIS 6.0 WebDAV)

กลุ่มช่องโหว่ LPE ปี 2026:

- CVE-2026-43503 (DirtyClone)
- CVE-2026-31431 (Copy Fail)
- CVE-2026-43284 / CVE-2026-43500 (Dirty Frag)

Tactics, Techniques, and Procedures

(MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

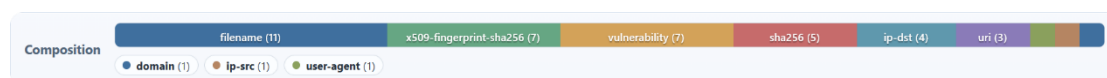
Tactic	Technique ID	Technique Name
Initial Access	T1190	Exploit Public-Facing Application
Execution	T1059.004	Command & Scripting: Unix Shell
	T1059.007	Command & Scripting: JavaScript
	T1059	Command & Scripting Interpreter
Persistence	T1505.003	Server Software Component: Web Shell
	T1547.001	Autostart Execution: Registry Run Keys
Persistence	T1053.005	Scheduled Task/Job: Scheduled Task/Cron
Privilege Escalation	T1068	Exploitation for Privilege Escalation
	T1055.012	Process Injection: Process Hollowing
Defense Evasion	T1036.005	Masquerading: Match Legitimate Name
Credential Access	T1078	Valid Accounts
	T1552.001	Unsecured Credentials: Credentials In Files
	T1110.003	Brute Force: Password Spraying
	T1539	Steal Web Session Cookie
Discovery	T1082	System Information Discovery
	T1083	File & Directory Discovery
Lateral Movement	T1072	Software Deployment Tools

Tactic	Technique ID	Technique Name
Command & Control	T1071.001	Application Layer Protocol: Web Protocols
	T1090.001	Proxy: Internal Proxy
Collection	T1113	Screen Capture

Indicators of Compromise (IoCs)

Indicators of Compromise (IoCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IoCs ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:



ตารางที่ 1: หมายเลขไอพีและโดเมนระบบผู้ก่อเหตุ (Network Indicators)

Indicator Value	Type	Context / Role Description	ASN & Location
43.246.208[.]207	IPv4	Staging Server / Open Directory / VShell C2 (Port 21083)	AS132883 (TOPIDC, Hong Kong)
103.97.0[.]57	IPv4	Operator SSH Client IP (เชื่อมต่อไปยัง 43[.]246[.]208[.]207)	AS133073 (HK Kwaifong Group, Hong Kong)
118.107.222[.]232	IPv4	Overlapping TLS Certificate Server (CN = www)	AS55720 (The Gigabit, Malaysia)
202.181.27[.]115	IPv4	Hades Implant C2 Server (Port 12443) / Overlapping TLS	AS134196 (Converged Communications, Hong Kong)
redhatupdating432.dnsrd[.]com	Domain	Threat Actor C2 Domain resolving to 43[.]246[.]208[.]207	External DNS

ตารางที่ 2: ค่าแฮชของไฟล์มัลแวร์และไบนารี (Cryptographic Hashes - SHA256)

Target Payload	Description / Binary Identification	SHA-256 Hash
VShell Linux Stage 1	VShell Linux stage 1 payload (Port 21083)	0f8c905aa25c86f85454acb 7e77bf5c50220c2a82e5b6 9a33741e55c8a85f2fc
VShell Windows Stage 1	VShell Windows stage 1 payload (Port 21083)	a9447ae174f4aa54f760b7 d7cc985c1a970f31e151d3 ff66fac247f99ba1b509
VShell Linux Stage 2	VShell Linux stage 2 payload (Port 21083)	ec7e9ab43a0cc65d29f0b8 4a93ba88c43d01fed3dec5 c968525dc73c03cbfda2
VShell Windows Stage 2	VShell Windows stage 2 payload (Port 21083)	b65b7ede835ebba36294d 52d7780065523340ee09b b8b209ef2dc495e53dfd53
Hades Linux Binary	Hades Go Implant Linux build (multipathd_04d0)	d252ee7b348b7e43e432d 8fb154465838f5cd5fb5649 05323460e6f0a0c7d1e2

ตารางที่ 3: ใบรับรองอิเล็กทรอนิกส์ (TLS Certificates - CN = www, JA4X Overlap)

IP Address	Port	Issuer Organization	Issuer Unit	Certificate SHA-256 Hash
43.246.208[.1207	443	Web Services	Infrastructure Team	576C70E12BE8B2E8E7C 35A5FEB082E90621989 ADCE8E64400126918D3 7F13E49

IP Address	Port	Issuer Organization	Issuer Unit	Certificate SHA-256 Hash
43.246.208[.]207	443	Digital Solutions	Platform Engineering	5633BC0033FDE3AAD9 29D6CBD47C554E2641 80360B017AAE04687C2 D6D83F753
43.246.208[.]207	19443	Cloud Platform	Platform Engineering	DBBB8A11A239DA11CB AF99F847A2D032F34D3 B522E13B0FD4EF7B264 9DA7123B
43.246.208[.]207	443	Web Services	Platform Engineering	9FF4B6D3B7DBB023BA D65D2538ADE745D46B 763E5A12116C9C83AA2 F6F5D96AA
118.107.222[.]232	443	Internet Technologies	Platform Engineering	2A4CB412EFA93FED7C3 B3B3E49D6247B11A95C E9FDDF71D9FE9DB8E5F 0068E0D
202.181.27[.]115	12443	Data Center	Web Operations	58338A93FEE4E008EA2 8E459C4D1598313D152 4763AB13894AB63BF2B EC4302A
202.181.27[.]115	12443	Online Services	Web Operations	FF662B60F6A142F9929 2FBDD65DD1CCD79DC9 628686DDF5935C92F7F B1B62A81

ตารางที่ 4: รูปแบบจุดเชื่อมต่อ URI และไฟล์พารบนเชิร์ฟเวอร์ (Artifact URIs & Paths)

Parameter Type	Pattern / Path Value	Description / Context
User-Agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36	User-Agent หลักของ Hades Implant
Hades C2 Check-in	/assets/app.min.js	URI สำหรับมัลแวร์ Hades เช็กอินเข้า C2
Hades C2 Tasking	/assets/vendor.js	URI สำหรับมัลแวร์ Hades รับคำสั่งจาก C2
Hades C2 Upload	/assets/main.js	URI สำหรับมัลแวร์ Hades ส่งผลลัพธ์กลับ C2
Web Shell Relative Path	/storage/Counter/nine/.journald-cache.php	Exact Relative Path สำหรับการ Threat Hunting
Web Shell Path	/[Web Root]/.journald-cache.php	พาร PHP Web Shell ซ่อนตัวบนเว็บเซิร์ฟเวอร์ MOF (Sanitized)
GlassFish Shell WAR	shell.war / itcenter-docs.war	แพ็คเกจ WAR ฝั่ง JSP Shell บน GlassFish

แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- **NIDS/SIEM Outbound Traffic Alerting:** กำหนดกฎ Alert แจ้งเตือนทันทีเมื่อพบว่าเว็บเซิร์ฟเวอร์ (เช่น Apache, GlassFish, Nginx) มีการเปิดการเชื่อมต่อขาออกไปยังพอร์ตบริการปกติภายใน ได้แก่ พอร์ต 10000 (HiveServer2) หรือพอร์ต 50070 (WebHDFS)
- **EDR Process Behavior Rules:** ตรวจสอบการรันโปรแกรม ctfmon.exe, csrss.exe นอกสสารระบบ C:\Windows\System32\ และตรวจสอบพฤติกรรม Process Hollowing เข้าไปใน svchost.exe
- **Hermes WebUI & Output Fingerprinting:** ทำการตั้งค่าสแกนหาแฮตเตอร์ HTTP Server: HermesWebUI และบล็อกพาธ /hermes-results/ บนเครือข่าย
- **ตรวจจับจิ้งหะคำสั่ง AI Agent:** ตั้งกฎ Alert ตรวจสอบการรันคำสั่งสแกนยกระดับสิทธิ์ที่รวดเร็วและสม่ำเสมอเกินจิ้งหะมนุษย์ปกติ (เช่น การสั่งรัน LinPEAS หรือสแกน SUID ถัดไปจนเกิด Broken-pipe Error)

การป้องกัน (Prevention)

- ยกเลิกการตั้งค่าโหมดการยืนยันตัวตนแบบ NONE ใน HiveServer2 โดยเปลี่ยนไปบังคับใช้ Kerberos หรือ LDAP Authentication
- เปิดใช้งานมาตรการ Hive UDF Blocklist ตามคำแนะนำของ Cloudera/Apache เพื่อห้ามไม่ให้ผู้ใช้ลงทะเบียนไฟล์ Java JAR รันคำสั่ง OS Command
- **GlassFish Console Protection:** เปลี่ยนรหัสผ่านเริ่มต้นของคอนโซลผู้ดูแลระบบ GlassFish ทันที และจำกัดสิทธิ์การเข้าถึงให้อยู่เฉพาะใน Management VLAN เท่านั้น
- **Patching Linux Systems:** อัปเดต Sudo เป็นเวอร์ชัน 1.9.5p2 ขึ้นไป (แก้ไข CVE-2021-3156) อัปเดต Polkit (แก้ไข CVE-2021-4034) และอัปเดต Linux Kernel ล่าสุด เพื่อปิดช่องโหว่ DirtyClone (CVE-2026-43503), Copy Fail (CVE-2026-31431) และ Dirty Frag (CVE-2026-43284)
- **Patching Windows Systems:** ปิดการใช้งานโปรโตคอล WebDAV บน IIS 6.0 และทำการย้ายระบบออกจาก Windows Server 2003 อย่างเร่งด่วน

การรับมือ (Response)

- แยกอุปกรณ์ที่ติดเชื้อ: หากตรวจพบการบุกรุก ให้รีบตัดการเชื่อมต่อเครื่องที่มีการบุกรุกนั้นออกจากเครือข่ายเพื่อป้องกันการแพร่กระจาย
- ดำเนินการสแกนค้นหาไฟล์ซ่อนเร้นแบบ Recursive ในทุกไดเรกทอรีของเว็บเซิร์ฟเวอร์ โดยเฉพาะไฟล์ PHP ขึ้นต้นด้วยจุด เช่น .journald-cache.php และไฟล์ Java WAR ใน GlassFish เช่น shell.war, itcenter-docs.war
- บล็อกหมายเลข IP และโดเมนของผู้ก่อเหตุทั้ง 4 หมายเลข บน Firewall และ Proxy ทุกจุดดัง IP ต่อไปนี้ :
 - 43.246.208[.]207
 - 103.97.0[.]57
 - 118.107.222[.]232
 - 202.181.27[.]115
- ดัดเซชันการใช้งาน (Revoke Session Tokens/Cookies) ของระบบแอตมินคณะกรรมการ ICT และระบบ Alfresco ทั้งหมด
- บังคับเปลี่ยนรหัสผ่านของบัญชีอีเมลทั้งหมดในเครือข่ายที่สงสัยว่าตกเป็นเป้าหมาย Password Spraying

อ้างอิง (References)

- CISA / NVD (CVE-2021-3156, CVE-2021-4034, CVE-2017-7269, CVE-2026-43503, CVE-2026-31431, CVE-2026-43284)
- Nous Research, "Hermes Agent: Autonomous AI Agent Framework", GitHub Repository, 2026. Available: <https://github.com/nousresearch/hermes-agent>



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://forms.gle/2cTSw2fDoMzFDGEW9>



จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th